

Change record — P5 Risk-Based Patch and Vulnerability Management Program

Retroactive change record, written to the standard Halden uses for every change (feeds the change log and the P10 governance dashboard). In a small company the same person often proposes and approves; that separation is documented honestly rather than pretended.

This record covers the **build of the programme**. Individual remediation changes (for example updating FW01 firmware, or cleaning up a P0 finding) each get their own record derived from this template — a worked example of the P0 case is in the last section.

Field	Value
Change ID	CHG-2026-007
Title	P5 — Risk-based patch and vulnerability management programme (WSUS rings, Linux patching, weekly scans, prioritisation engine)
Raised by	IT (Muhammad Ibrahim Akmal)
Approved by	Managing Director (<i>business owner of the fictional Halden; see the lab note</i>)
Date raised	2026-10-02
Planned implementation	Phase by phase, out of hours (see §4)
Category / risk	Security programme — Medium risk overall, with High-risk individual steps (server reboots, firewall firmware)
Affected services	All patching and update delivery; server and workstation reboots; firewall firmware; the service desk (new ticket type)
Affected systems	LNX01 (scanner), the WSUS host, DC01, DC02, FS01, OPS01, FW01, WS01, WS02

1. Description of the change

Introduce a risk-based patch and vulnerability management programme:

- **Patch rings:** three Windows Update rings (Pilot, Broad, Servers) with client-side targeting by Group Policy and a coded pilot gate before broader approval; domain controllers patched separately in DC02-then-DC01 order.
- **Linux patching:** an Ansible playbook that patches one host at a time with pre- and post-checks, plus unattended security updates between cycles.
- **Weekly authenticated scanning:** Greenbone Community Edition on LNX01, scoped to the lab network only, with the web UI reachable only through an SSH tunnel.
- **A prioritisation engine:** a Python tool that enriches findings with CISA KEV and FIRST EPSS data, joins asset exposure and criticality, and produces a tiered P0–P4 work list with SLA dates.

- **A closure loop:** P0/P1 items become service-desk tickets, and a ticket only closes when a re-scan confirms the finding is gone.
- **Policy and reporting:** a patch and vulnerability policy with an exception process, and a monthly management report.

2. Reason for the change

Halden patches when someone has time. Nobody knows which machines are missing which updates, the firewall firmware is two years old, and a cyber-insurance scan returned 400 "critical" findings that IT cannot act on as a list. The change replaces "patch when we remember" with a prioritised, verifiable and reportable programme: effort goes to the vulnerabilities an attacker would actually use, and the business can see what is open, what is overdue and what it has chosen to accept.

3. Impact and risk

Area	Impact	Mitigation
Users	Machines restart to install updates; a brief slowdown during the window	Restarts scheduled outside active hours; pilot ring catches a bad update first
Servers	Reboots required; a failed patch could take a service down	Snapshots before the window; fixed patch order; post-checks that stop the run on failure
Domain controllers	An outage would stop logons for the whole company	DC02 then DC01, never together; replication and <code>dcdiag</code> checked between them
Firewall firmware	A failed update could interrupt internet access and VPN	Config backup before the update; documented rollback; done in a window with the business informed
Service desk	A new ticket type and priority fields	Escalation matrix documented; tickets carry the tier and the due date
Risk of scanning	A scanner pointed at the wrong address is an incident	Hard lab-range guard in the scripts; targets only created from a validated scope file

4. Implementation plan (phases)

Phase	Work	Verification
0	Policy, tier model and SLA targets written and circulated	Policy reviewed; tiers agreed
1	WSUS rings, GPO client-side targeting, pilot gate, maintenance script	Rings visible; pilot gate blocks approval when unhealthy
2	Ansible Linux patching plus unattended security updates	Playbook run recorded; post-checks pass
3	Scanner deployed and hardened; credentialed scan accounts; weekly schedule	Scan completes across the scoped host set
4	Prioritisation engine, ticket generation, dashboard/report	Work list produced; P0/P1 ticketed with due dates

Phase	Work	Verification
5	Remediation, verification rescan, exception register	Closure report shows findings closed by re-scan

5. Test plan (acceptance)

1. Approve a security update with the pilot below 90% installed — **the approval is refused.**
 2. Patch DC02 and confirm DC01 is not touched until DC02 passes its post-check.
 3. Validate the scope file with a deliberately wrong address — **the guard aborts.**
 4. Run the prioritisation engine over a scan export — every finding gets a tier, an SLA date and a score, and the tier distribution is shown.
1. Attempt to close a ticket without a verification scan — **not permitted by the process.**
 2. Run the engine twice over the same input — identical output (deterministic and idempotent).

6. Backout plan

Each phase is snapshotted before it runs (`snap-p5-ph<N>-before`). Backout is to revert the snapshot and remove the artefacts the phase added: delete the update GPOs and rings (patching returns to default behaviour), stop and remove the scanner containers in `/opt/greenbone` , and unapprove any update approved for the broader rings. Individual remediations are backed out per their own record: uninstall the update from the pilot ring, or restore the firewall configuration from the pre-update backup. Domain controllers are fixed forward where possible.

7. Worked example — the record for a single P0 remediation

Field	Value
Change ID	CHG-2026-008 (example)
Title	P0 remediation: apply the vendor fix for a known-exploited vulnerability on FW01
Category / risk	Emergency — edge device, High risk
Reason	A P0 finding: a KEV vulnerability on the internet-exposed firewall
Order of work	1. Compromise check (logs, admin accounts, config compared to the last known-good backup). 2. Download and store the configuration backup. 3. Apply the firmware update. 4. Verify interfaces, VPN and rule base. 5. Re-scan to confirm the finding is gone.
Backout	Restore the configuration backup and revert the firmware if the update fails or breaks the rule base
Verification	Rescan shows the finding is no longer reported; the change record is closed

8. Post-implementation review

To be completed when the last phase is verified: actual completion date, acceptance test results, anything that went wrong, and whether any phase overran. Results are recorded in `projects/p05-vuln-management/README.md` with a source file for every number.

Note: this is a home-lab change record for a fictional company (Halden Distribution Ltd.). The technical content, scripts and test results are real; the business approval line represents the lab owner's decision, not a real customer sign-off.

Halden Distribution Ltd. — home-lab portfolio artifact (fictional company, real configurations). Generated from p05-change-record.md on 2026-10-02.